

PCI Detailed Vulnerability Report

Prepared for: Trainpetdog Limited

Scan Date: 06/30/2014 10:05:03

Generated: 06/30/2014 10:17:12



Table of Contents

Part 1. Scan Information	1
Part 2. Vulnerability Details	1
Host IP: 75.126.159.2 (75.126.159.2-static.reverse.softlayer.com).....	1
Host IP: 75.126.159.3 (75.126.159.3-static.reverse.softlayer.com).....	11

Part 1. Scan Information			
Scan Customer Company:	Trainpetdog Limited		
ASV Company:	Clone Systems, Inc.		
Date scan was completed:	06/30/2014 10:05:03	Scan expiration date:	09/28/2014 10:05:03

Part 2. Vulnerability Details			
75.126.159.2 (75.126.159.2-static.reverse.softlayer.com)			
IP Address	Severity Level	Compliance Status	Details
75.126.159.2	Medium	Fail	Application: http Port: 80 Protocol: tcp VATID: 57640 Synopsis : The remote web application discloses path information. Description : At least one web application hosted on the remote web server discloses the physical path to its directories when a malformed request is sent to it. Leaking this kind of information may help an attacker fine-tune attacks against the application and its backend. Solution : Filter error messages containing path information. CVSS Base Score : 5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N) Plugin output : The request GET /manual/en/howto/ssi.html HTTP/1.1\r Host: 75.126.159.2-static.reverse.softlayer.com\r Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1\r Accept-Language: en\r Connection: Close\r Cookie: <!--#include file="nessus840136352.html"-->\r User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r Pragma: no-cache\r Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*\r \r produces the following path information : something else that you can do with the <code>exec</code> element. You can actually have SSI execute a command using the

			shell (<code><code>/bin/sh</code></code>, to be precise - or the DOS shell, if you're on Win32). The following, for example, will give you a directory listing.</p>
75.126.159.2	Medium	Fail	Application: http Port: 80 Protocol: tcp VATID: 57640 Synopsis : The remote web application discloses path information. Description : At least one web application hosted on the remote web server discloses the physical path to its directories when a malformed request is sent to it. Leaking this kind of information may help an attacker fine-tune attacks against the application and its backend. Solution : Filter error messages containing path information. CVSS Base Score : 5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N) Plugin output : The request GET /manual/en/howto/ssi.html HTTP/1.1\r Host: 75.126.159.2-static.reverse.softlayer.com\r Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1\r Accept-Language: en\r Connection: Close\r Cookie: <!--#include file="nessus840136352.html"-->\r User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r Pragma: no-cache\r Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*\r \r produces the following path information : something else that you can do with the <code><code>exec</code></code> element. You can actually have SSI execute a command using the shell (<code><code>/bin/sh</code></code>, to be precise - or the DOS shell, if you're on Win32). The following, for example, will give you a directory listing.</p>
75.126.159.2	Medium	Fail	Application: http Port: 80 Protocol: tcp VATID: 57640 Synopsis :

			The remote web application discloses path information. Description : At least one web application hosted on the remote web server discloses the physical path to its directories when a malformed request is sent to it. Leaking this kind of information may help an attacker fine-tune attacks against the application and its backend. Solution : Filter error messages containing path information. CVSS Base Score : 5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N) Plugin output : <pre> The request GET /manual/en/howto/ssi.html HTTP/1.1\r Host: 75.126.159.2-static.reverse.softlayer.com\r Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1\r Accept-Language: en\r Connection: Close\r Cookie: <!--#include file="nessus840136352.html"-->\r User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r Pragma: no-cache\r Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*\r \r </pre> produces the following path information : something else that you can do with the <code><code>exec</code></code> element. You can actually have SSI execute a command using the shell (<code><code>/bin/sh</code></code>), to be precise - or the DOS shell, if you're on Win32). The following, for example, will give you a directory listing.</p>
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 14772 Synopsis : This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to identify common services which might have been missed because of a network problem. Solution :

			See below Plugin output : A web server is running on this port
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 11032 Synopsis : It is possible to enumerate directories on the web server. Description : This plugin attempts to determine the presence of various common directories on the remote web server. By sending a request for a directory, the web server response code indicates if it is a valid directory or not. See also : http://projects.webappsec.org/Predictable-Resource-Location Solution : n/a Plugin output : The following directories were discovered: /cgi-bin, /icons, /mail, /manual While this is not, in and of itself, a bug, you should manually inspect these directories to ensure that they are in compliance with company security standards Other references : OWASP:OWASP-CM-006
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 10107 Synopsis : A web server is running on the remote host. Description : This plugin attempts to determine the type and the version of the remote web server. Solution :

			n/a Plugin output : The remote web server type is : Apache and the 'ServerTokens' directive is ProductOnly Apache does not offer a way to hide the server type.
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 24260 Synopsis : Some information about the remote HTTP configuration can be extracted. Description : This test gives some information about the remote HTTP protocol - the version used, whether HTTP Keep-Alive and HTTP pipelining are enabled, etc... This test is informational only and does not denote any security problem. Solution : n/a Plugin output : Protocol version : HTTP/1.1 SSL : no Keep-Alive : no Options allowed : (Not implemented) Headers : Date: Mon, 30 Jun 2014 08:05:50 GMT Server: Apache Vary: Accept-Encoding Content-Length: 0 Connection: close Content-Type: text/html
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 43111 Synopsis : This plugin determines which HTTP methods are allowed on various CGI directories.

Description :

By calling the OPTIONS method, it is possible to determine which HTTP methods are allowed on each directory.

As this list may be incomplete, the plugin also tests - if 'Thorough tests' are enabled or 'Enable web applications tests' is set to 'yes' in the scan policy - various known HTTP methods on each directory and considers them as unsupported if it receives a response code of 400, 403, 405, or 501.

Note that the plugin output is only informational and does not necessarily indicate the presence of any security vulnerabilities.

Solution :

n/a

Plugin output :

Based on the response to an OPTIONS request :

- HTTP methods GET HEAD OPTIONS POST are allowed on :

/icons
/manual
/manual/de
/manual/de/faq
/manual/de/mod
/manual/en
/manual/en/developer
/manual/en/faq
/manual/en/howto
/manual/en/misc
/manual/en/mod
/manual/en/platform
/manual/en/programs
/manual/en/rewrite
/manual/en/ssl
/manual/en/vhosts

Based on tests of each method :

- HTTP methods ACL BASELINE-CONTROL BCOPY BDELETE BMOVE BPROPFIND BPROPPATCH CHECKIN CHECKOUT COPY DEBUG DELETE GET HEAD INDEX LABEL LOCK MERGE MKACTIVITY MKCOL MKWORKSPACE MOVE NOTIFY OPTIONS ORDERPATCH PATCH POLL POST PROPFIND PROPPATCH PUT REPORT RPC_IN_DATA RPC_OUT_DATA SEARCH SUBSCRIBE UNCHECKOUT UNLOCK UNSUBSCRIBE UPDATE VERSION-CONTROL X-MS-ENUMATTS are allowed on :

/cgi-bin

			- HTTP methods GET HEAD OPTIONS POST are allowed on : / /icons /mail /manual /manual/de /manual/de/faq /manual/de/mod /manual/en /manual/en/developer /manual/en/faq /manual/en/howto /manual/en/misc /manual/en/mod /manual/en/platform /manual/en/programs /manual/en/rewrite /manual/en/ssl /manual/en/vhosts - Invalid/unknown HTTP methods are allowed on : /cgi-bin
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 49704 Synopsis : Links to external sites were gathered. Description : Nessus gathered HREF links to external sites by crawling the remote web server. Solution : n/a Plugin output : 77 external URLs were gathered on this web server : URL... - Seen on... http://apache.webthing.com/mod_proxy_html/ - /manual/en/urlmapping.html http://apr.apache.org - /manual/en/install.html http://apr.apache.org/ - /manual/en/glossary.html http://bugs.apache.org/index/full/467 - /manual/en/misc/perf-tuning.html http://cgi-spec.golux.com/ - /manual/es/glossary.html

<http://cgiwrap.sourceforge.net/> - /manual/en/misc/security_tips.html
<http://developer.novell.com/ndk/apache.htm> - /manual/en/platform/networkare.html
<http://developer.novell.com/ndk/cldap.htm> - /manual/en/platform/networkare.html
<http://developer.novell.com/ndk/cwppdk.htm> - /manual/en/platform/networkare.html
<http://developer.novell.com/ndk/libc.htm> - /manual/en/platform/networkare.html
http://dir.yahoo.com/Computers_and_Internet/Software/Internet/World_Wide_Web/Servers/Log_Analysis_Tools/ - /manual/en/logs.html
http://dmoz.org/Computers/Software/Internet/Site_Management/Log_analysis/ - /manual/en/logs.html
<http://en.wikipedia.org/wiki/PCRE> - /manual/en/glossary.html
<http://hoohoo.ncsa.uiuc.edu/cgi/overview.html> - /manual/en/glossary.html
http://hpwww.ec-lyon.fr/~vincent/apache/mod_put.html - /manual/en/platform/ebcdic.html
<http://httpd.apache.org/> - /manual/en/index.html
http://httpd.apache.org/bug_report.html - /manual/en/platform/networkare.html
<http://httpd.apache.org/dev/verification.html> - /manual/en/install.html
<http://httpd.apache.org/docs-project/> - /manual/en/index.html
<http://httpd.apache.org/docs/> - /manual/en/index.html
<http://httpd.apache.org/docs/2.0/upgrading.html> - /manual/en/upgrading.html
<http://httpd.apache.org/docs/2.2/> - /manual/en/install.html
<http://httpd.apache.org/docs/2.2/suexec.html> - /manual/en/suexec.html
<http://httpd.apache.org/download.cgi> - /manual/en/install.html
<http://httpd.apache.org/download.cgi#verify> - /manual/en/install.html
<http://httpd.apache.org/lists.html#http-announce> - /manual/en/misc/security_tips.html
<http://httpd.apache.org/lists.html#http-dev> - /manual/en/developer/index.html
<http://httpd.apache.org/userslist.html> - /manual/en/platform/windows.html
<http://ietf.org/rfc/rfc2616.txt> - /manual/en/glossary.html
<http://jakarta.apache.org/tomcat/> - /manual/en/new_features_2_2.html
<http://java.apache.org/> - /manual/en/platform/ebcdic.html
<http://modules.apache.org/> - /manual/en/filter.html
<http://nasm.sourceforge.net/> - /manual/en/platform/networkare.html
<http://online.securityfocus.com/bid/4876/info/> - /manual/en/misc/security_tips.html
<http://support.microsoft.com/kb/292539/> - /manual/en/platform/windows.html
<http://support.novell.com/misc/patlist.htm#nw> - /manual/en/platform/networkare.html
http://threebit.net/tutorials/apache2_modules/tut1/tutorial1.html - /manual/en/developer/index.html
http://threebit.net/tutorials/apache2_modules/tut2/tutorial2.html - /manual/en/developer/index.html
<http://wiki.apache.org/httpd/FAQ> - /manual/en/index.html
<http://wiki.apache.org/httpd/Rewrite> - /manual/en/rewrite/index.html
<http://www.apache.org/> - /manual/en/index.html
<http://www.apache.org/dist/httpd/binaries/networkare> - /manual/en/platform/networkare.html
<http://www.apache.org/licenses/> - /manual/en/license.html
<http://www.apache.org/licenses/LICENSE-2.0> - /manual/en/index.html
<http://www.apachetutor.org/> - /manual/en/developer/index.html
<http://www.apachetutor.org/dev/brigades> - /manual/en/developer/index.html
<http://www.apachetutor.org/dev/config> - /manual/en/developer/index.html
<http://www.apachetutor.org/dev/pools> - /manual/en/developer/index.html
<http://www.apachetutor.org/dev/request> - /manual/en/developer/index.html
<http://www.apachetutor.org/dev/reslist> - /manual/en/developer/index.html
<http://www.boutell.com/cgiic/> - /manual/en/howto/cgi.html
<http://www.cpan.org/> - /manual/en/howto/cgi.html
<http://www.cronolog.org/> - /manual/en/logs.html
<http://www.gnu.org/> - /manual/en/install.html
<http://www.gnu.org/software/gcc/gcc.html> - /manual/en/install.html
<http://www.gzip.org/zlib/> - /manual/en/platform/networkare.html
<http://www.hpl.hp.com/techreports/Compaq-DEC/WRL-95-4.html> - /manual/en/misc/perf-tuning.html

			http://www.hwg.org/lists/hwg-servers/ - /manual/en/howto/cgi.html http://www.ics.uci.edu/pub/ietf/http/draft-ietf-http-connection-00.txt - /manual/en/misc/perf-tuning.html http://www.ietf.org/rfc/rfc2396.txt - /manual/en/glossary.html http://www.ietf.org/rfc/rfc2817.txt - /manual/en/new_features_2_2.html http://www.ietf.org/rfc/rfc3546.txt - /manual/en/glossary.html http://www.ietf.org/rfc/rfc3875 - /manual/en/howto/cgi.html http://www.ntp.org - /manual/en/install.html http://www.onlamp.com/pub/ct/38 - /manual/en/developer/index.html http://www.openssl.org/ - /manual/en/glossary.html http://www.openssl.org/source/ - /manual/en/platform/netware.html http://www.pcre.org/ - /manual/en/glossary.html http://www.perl.org/ - /manual/en/install.html http://www.php.net/ - /manual/en/platform/ebcdic.html http://www.serverwatch.com/tutorials/article.php/1132731 - /manual/en/env.html http://www.siemens.de/servers/bs2osd/osdbc_us.htm - /manual/en/platform/ebcdic.html http://www.w3.org/CGI/ - /manual/en/glossary.html http://www.w3.org/Daemon/ - /manual/en/platform/ebcdic.html http://www.w3.org/Protocols/HTTP/Performance/Pipeline.html - /manual/en/misc/perf-tuning.html http://www.w3.org/Protocols/rfc2616/rfc2616.txt - /manual/en/logs.html http://www.webdav.org/ - /manual/en/mod/index.html
75.126.159.2	Low	Pass	Application: general Port: 0 Protocol: udp VATID: 10287 Synopsis : It was possible to obtain traceroute information. Description : Makes a traceroute to the remote host. Solution : n/a Plugin output : For your information, here is the traceroute from 38.123.140.114 to 75.126.159.2 : 38.123.140.114 38.123.140.1 38.122.22.61 154.24.24.1 154.54.85.149 154.54.42.101 154.54.5.233 4.68.63.173 4.53.116.66 173.192.18.153 173.192.18.134 173.192.18.255 66.228.118.178 75.126.159.2

75.126.159.2	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 10180 Synopsis : It was possible to identify the status of the remote host (alive or dead) Description : This plugin attempts to determine if the remote host is alive using one or more ping types : - An ARP ping, provided the host is on the local subnet and Nessus is running over ethernet. - An ICMP ping. - A TCP ping, in which the plugin sends to the remote host a packet with the flag SYN, and the host will reply with a RST or a SYN/ACK. - A UDP ping (DNS, RPC, NTP, etc). Solution : n/a Plugin output : The remote host is up The remote host replied to an ICMP echo packet
75.126.159.2	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 12053 Synopsis : It was possible to resolve the name of the remote host. Description : Nessus was able to resolve the FQDN of the remote host. Solution : n/a Plugin output : 75.126.159.2 resolves as 75.126.159.2-static.reverse.softlayer.com.

75.126.159.3 (75.126.159.3-static.reverse.softlayer.com)			
IP Address	Severity Level	Compliance Status	Details
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 26194 Synopsis : The remote web server might transmit credentials in cleartext. Description : The remote web server contains several HTML form fields containing an input of type 'password' which transmit their information to a remote web server in cleartext. An attacker eavesdropping the traffic between web browser and server may obtain logins and passwords of valid users. Solution : Make sure that every sensitive form transmits content over HTTPS. CVSS Base Score : 2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N) Plugin output : Page : /bugzilla/ Destination Page: /bugzilla/index.cgi Page : /bugzilla/search_plugin.cgi Destination Page: /bugzilla/search_plugin.cgi Page : /bugzilla/describecomponents.cgi Destination Page: /bugzilla/describecomponents.cgi Page : /bugzilla/enter_bug.cgi Destination Page: /bugzilla/enter_bug.cgi Page : /bugzilla/query.cgi Destination Page: /bugzilla/query.cgi Page : /bugzilla/buglist.cgi Destination Page: /bugzilla/buglist.cgi Page : /bugzilla/page.cgi?id=quicksearch.html Destination Page: /bugzilla/page.cgi Page : /bugzilla/createaccount.cgi Destination Page: /bugzilla/createaccount.cgi

			Page : /bugzilla/report.cgi Destination Page: /bugzilla/report.cgi Page : /bugzilla/index.cgi?GoAheadAndLogIn=1 Destination Page: /bugzilla/index.cgi Page : /bugzilla/token.cgi Destination Page: /bugzilla/index.cgi Page : /bugzilla/index.cgi Destination Page: /bugzilla/index.cgi Page : /bugzilla/page.cgi?id=release-notes.html Destination Page: /bugzilla/page.cgi Page : /bugzilla/page.cgi Destination Page: /bugzilla/page.cgi Page : /bugzilla/createaccount.cgi?GoAheadAndLogIn=1 Destination Page: /bugzilla/createaccount.cgi Other references : CWE:522, CWE:523, CWE:718, CWE:724
75.126.159.3	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 34324 Synopsis : Authentication credentials might be intercepted. Description : The remote FTP server allows the user's name and password to be transmitted in clear text, which could be intercepted by a network sniffer or a man-in-the-middle attack. Solution : Switch to SFTP (part of the SSH suite) or FTPS (FTP over SSL/TLS). In the latter case, configure the server so that control connections are encrypted. CVSS Base Score : 2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N) Plugin output : This FTP server does not support 'AUTH TLS'. Other references : CWE:522, CWE:523
75.126.159.3	Low	Pass	Application: unknown Port: 55427

			Protocol: udp VATID: 11111 Synopsis : An ONC RPC service is running on the remote host. Description : By sending a DUMP request to the portmapper, it was possible to enumerate the ONC RPC services running on the remote port. Using this information, it is possible to connect and bind to each service by sending an RPC request to the remote port. Solution : n/a Plugin output : The following RPC services are available on UDP port 55427 : - program: 100024 (status), version: 1
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 11032 Synopsis : It is possible to enumerate directories on the web server. Description : This plugin attempts to determine the presence of various common directories on the remote web server. By sending a request for a directory, the web server response code indicates if it is a valid directory or not. See also : http://projects.webappsec.org/Predictable-Resource-Location Solution : n/a Plugin output : The following directories were discovered: /bugzilla While this is not, in and of itself, a bug, you should manually inspect these directories to ensure that they are in compliance with company security standards

			Other references : OWASP:OWASP-CM-006
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 10662 Synopsis : Nessus crawled the remote web site. Description : This script makes a mirror of the remote web site(s) and extracts the list of CGIs that are used by the remote host. It is suggested that you change the number of pages to mirror in the 'Options' section of the client. Solution : n/a Plugin output : Webmirror performed 124 queries in 17s (7.294 queries per second) The following CGI have been discovered: + CGI: /bugzilla/buglist.cgi Methods: GET,POST Argument: Bugzilla_login Argument: Bugzilla_password Argument: Bugzilla_restrictlogin Argument: GoAheadAndLogIn Value: Log in Argument: no_redirect Value: 0 Argument: quicksearch + CGI: /bugzilla/page.cgi Methods: GET,POST Argument: Bugzilla_login Argument: Bugzilla_password Argument: Bugzilla_restrictlogin Argument: GoAheadAndLogIn Value: Log in Argument: id Value: quicksearch.html Value: release-notes.html


```

+ CGI: /bugzilla/index.cgi
Methods: GET,POST
Argument: Bugzilla_login
Argument: Bugzilla_password
Argument: Bugzilla_restrictlogin
Argument: GoAheadAndLogIn
Value: 1
Value: Log in
Value: 1#forgot

+ CGI: /bugzilla/token.cgi
Methods: GET,POST
Argument: a
Value: reqpw
Argument: loginname
Argument: token
Value: 1404114650-JiyXVX0RJj597Majd06ULaj-10FpRx5hAiax6egVVUc
Value: 1404114652-ZOyHM5t5pOtO2tlkmf8JWY5HHrJuKFLAEsRO3U0SryI
Value: 1404114653-rc9DfU04S0zkLmUg5JR6KX6IPzv_tSZbuzxxGGkZRuw
Value: 1404114657-mWaVwW69UNyK3nHKj6mSlnN5j26gyaOSfpGB2ivGw3o
Value: 1404114658-OCbb1hPwhTSeLuViUd4hdFg-oFJpB4mtq0H4mQE82c8
Value: 1404114659-LU-Y4oRhPuGHDjRHebnvPOZzVmp7Jv6hpztewOkDU6U
Value: 1404114660-XV0VQQUSTXPqUmCSDetmA4HEXwF8E4cqp2p21xz8l4Q
Value: 1404114661-GV6QJAKdmJf5QzeKL7Ep3q2f7CkuNEMg5pIKVsTKBV8
Value: 1404114662-FKs6g4WVonGRAsNnQ97QUI15Q3Vls2p9H2WJPsv1G8A

+ CGI: /bugzilla/search_plugin.cgi
Methods: POST
Argument: Bugzilla_login
Argument: Bugzilla_password
Argument: Bugzilla_restrictlogin
Argument: GoAheadAndLogIn
Value: Log in

+ CGI: /bugzilla/describecomponents.cgi
Methods: POST
Argument: Bugzilla_login
Argument: Bugzilla_password
Argument: Bugzilla_restrictlogin
Argument: GoAheadAndLogIn
Value: Log in

+ CGI: /bugzilla/enter_bug.cgi
Methods: POST
Argument: Bugzilla_login
Argument: Bugzilla_password
Argument: Bugzilla_restrictlogin
Argument: GoAheadAndLogIn
Value: Log in

```

			+ CGI: /bugzilla/query.cgi Methods: POST Argument: Bugzilla_login Argument: Bugzilla_password Argument: Bugzilla_restrictlogin Argument: GoAheadAndLogIn Value: Log in + CGI: /bugzilla/createaccount.cgi Methods: GET,POST Argument: Bugzilla_login Argument: Bugzilla_password Argument: Bugzilla_restrictlogin Argument: GoAheadAndLogIn Value: 1 Value: Log in Value: 1#forgot Argument: login Argument: token Value: 1404114653-86fapbNFXm57dVuN8iytgplQIsBCiSQO29GvcW-u7DM Value: 1404114659-jhZtDxl0vFPmKTK3y54AGjtLxyWRCP9dNQJeCFpoubg + CGI: /bugzilla/report.cgi Methods: POST Argument: Bugzilla_login Argument: Bugzilla_password Argument: Bugzilla_restrictlogin Argument: GoAheadAndLogIn Value: Log in + CGI: /bugzilla/docs/page.cgi Methods: GET Argument: id Value: quicksearch.html
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 49705 Synopsis : Email addresses were harvested from the web server. Description : Nessus harvested HREF mailto: links and extracted email addresses by crawling the remote web server. Solution :

			n/a Plugin output : The following email addresses have been gathered : - 'terry@mozilla.org', referenced from : /bugzilla/docs/en/html/credits.html - 'tara@tequilarists.org', referenced from : /bugzilla/docs/en/html/credits.html - 'mbarnson@sisna.com', referenced from : /bugzilla/docs/en/html/credits.html - 'mamta@linkexplore.com', referenced from : /bugzilla/createaccount.cgi - 'justdave@bugzilla.org', referenced from : /bugzilla/docs/en/html/credits.html - 'jake@bugzilla.org', referenced from : /bugzilla/docs/en/html/credits.html - 'endico@mozilla.org', referenced from : /bugzilla/docs/en/html/credits.html - 'dki@redhat.com', referenced from : /bugzilla/docs/en/html/credits.html
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 42057 Synopsis : Auto-complete is not disabled on password fields. Description : The remote web server contains at least HTML form field containing an input of type 'password' where 'autocomplete' is not set to 'off'. While this does not represent a risk to this web server per se, it does mean that users who use the affected forms may have their credentials saved in their browsers, which could in turn lead to a loss of confidentiality if any of them use a shared host or their machine is compromised at some point. Solution : Add the attribute 'autocomplete=off' to these fields to prevent

			browsers from caching credentials. Plugin output : Page : /bugzilla/ Destination Page: /bugzilla/index.cgi Page : /bugzilla/search_plugin.cgi Destination Page: /bugzilla/search_plugin.cgi Page : /bugzilla/describecomponents.cgi Destination Page: /bugzilla/describecomponents.cgi Page : /bugzilla/enter_bug.cgi Destination Page: /bugzilla/enter_bug.cgi Page : /bugzilla/query.cgi Destination Page: /bugzilla/query.cgi Page : /bugzilla/buglist.cgi Destination Page: /bugzilla/buglist.cgi Page : /bugzilla/page.cgi?id=quicksearch.html Destination Page: /bugzilla/page.cgi Page : /bugzilla/createaccount.cgi Destination Page: /bugzilla/createaccount.cgi Page : /bugzilla/report.cgi Destination Page: /bugzilla/report.cgi Page : /bugzilla/index.cgi?GoAheadAndLogIn=1 Destination Page: /bugzilla/index.cgi Page : /bugzilla/token.cgi Destination Page: /bugzilla/index.cgi Page : /bugzilla/index.cgi Destination Page: /bugzilla/index.cgi Page : /bugzilla/page.cgi?id=release-notes.html Destination Page: /bugzilla/page.cgi Page : /bugzilla/page.cgi Destination Page: /bugzilla/page.cgi Page : /bugzilla/createaccount.cgi?GoAheadAndLogIn=1 Destination Page: /bugzilla/createaccount.cgi
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 49704 Synopsis :

Links to external sites were gathered.

Description :

Nessus gathered HREF links to external sites by crawling the remote web server.

Solution :

n/a

Plugin output :

46 external URLs were gathered on this web server :

URL... - Seen on...

<http://aspn.activestate.com/ASPN/Downloads/ActivePerl/> - </bugzilla/docs/en/html/os-specific.html>
http://bugzilla.mozilla.org/enter_bug.cgi?product=Bugzilla;component=Documentation -
</bugzilla/docs/en/html/conventions.html>
http://bugzilla.mozilla.org/show_bug.cgi?id=186383 - </bugzilla/docs/en/html/security-webserver.html>
<http://bzd.mozilla.org/bugzilla/> - </bugzilla/docs/en/html/upgrade.html>
<http://httpd.apache.org/> - </bugzilla/docs/en/html/installation.html>
<http://httpd.apache.org/docs-2.0/mod/core.html#scriptinterpretersource> -
</bugzilla/docs/en/html/os-specific.html>
<http://landfill.bugzilla.org/> - </bugzilla/docs/en/html/using-intro.html>
<http://landfill.bugzilla.org/bugzilla-4.4-branch/> - </bugzilla/docs/en/html/myaccount.html>
<http://landfill.bugzilla.org/bugzilla-4.4-branch/page.cgi?id=bug-writing.html> -
</bugzilla/docs/en/html/bugreports.html>
<http://landfill.bugzilla.org/bugzilla-4.4-branch/query.cgi> - </bugzilla/docs/en/html/query.html>
http://landfill.bugzilla.org/bugzilla-4.4-branch/show_bug.cgi?id=1 -
/bugzilla/docs/en/html/bug_page.html
http://landfill.bugzilla.org/bugzilla-tip/enter_bug.cgi?product=WorldControl;format=guided -
</bugzilla/docs/en/html/cust-templates.html>
<http://online.securityfocus.com/bid/6501> - </bugzilla/docs/en/html/security-webserver.html>
<http://perl.apache.org> - </bugzilla/docs/en/html/installation.html>
<http://sourceforge.net/projects/fink/> - </bugzilla/docs/en/html/os-specific.html>
<http://sqlite.org/faq.html#q5> - </bugzilla/docs/en/html/configuration.html>
<http://support.microsoft.com/default.aspx?scid=kb;en-us;231998> -
</bugzilla/docs/en/html/configuration.html>
<http://support.microsoft.com/default.aspx?scid=kb;en-us;245225> -
</bugzilla/docs/en/html/configuration.html>
<http://wiki.mozilla.org/Bugzilla:FAQ> - </bugzilla/docs/en/html/using-intro.html>
<http://www.activestate.com/> - </bugzilla/docs/en/html/os-specific.html>
<http://www.bugzilla.org> - </bugzilla/docs/en/html/hintsandtips.html>
<http://www.bugzilla.org/docs/> - </bugzilla/docs/en/html/index.html>
<http://www.bugzilla.org/docs/developer.html> - </bugzilla/docs/en/html/cust-templates.html>
<http://www.bugzilla.org/download.html#localizations> - </bugzilla/docs/en/html/cust-templates.html>
<http://www.bugzilla.org/download/> - </bugzilla/docs/en/html/installation.html>
<http://www.bugzilla.org/download/#localizations> - </bugzilla/docs/en/html/newversions.html>
<http://www.bugzilla.org/releases/> - </bugzilla/docs/en/html/upgrade.html>
http://www.cert.org/tech_tips/malicious_code_mitigation.html#3 -

			/bugzilla/docs/en/html/security-bugzilla.html http://www.gnome.org/projects/dia - /bugzilla/docs/en/html/lifecycle.html http://www.macports.org/ - /bugzilla/docs/en/html/os-specific.html http://www.mysql.com - /bugzilla/docs/en/html/installation.html http://www.mysql.com/doc/en/Fulltext_Fine-tuning.html - /bugzilla/docs/en/html/configuration.html http://www.nncron.ru/ - /bugzilla/docs/en/html/extraconfig.html http://www.oracle.com/ - /bugzilla/docs/en/html/installation.html http://www.perl.org - /bugzilla/docs/en/html/installation.html http://www.postfix.org/ - /bugzilla/docs/en/html/os-specific.html http://www.postgresql.org/ - /bugzilla/docs/en/html/installation.html http://www.ravenbrook.com/project/p4dti/tool/cgi/bugzilla-schema/ - /bugzilla/docs/en/html/configuration.html http://www.template-toolkit.org - /bugzilla/docs/en/html/cust-templates.html https://bugzilla.mozilla.org/show_bug.cgi?id=201069 - /bugzilla/docs/en/html/parameters.html https://wiki.mozilla.org/Bugzilla:Addons - /bugzilla/docs/en/html/integration.html https://wiki.mozilla.org/Bugzilla:Bzr - /bugzilla/docs/en/html/installation.html https://wiki.mozilla.org/Bugzilla:L10n - /bugzilla/docs/en/html/newversions.html https://wiki.mozilla.org/Bugzilla:Moving_From_CVS_To_Bazaar - /bugzilla/docs/en/html/upgrade.html https://wiki.mozilla.org/Bugzilla:Prerequisites - /bugzilla/docs/en/html/os-specific.html https://wiki.mozilla.org/Bugzilla:Win32Install - /bugzilla/docs/en/html/os-specific.html
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 10107 Synopsis : A web server is running on the remote host. Description : This plugin attempts to determine the type and the version of the remote web server. Solution : n/a Plugin output : The remote web server type is : Apache and the 'ServerTokens' directive is ProductOnly Apache does not offer a way to hide the server type.
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 43111 Synopsis : This plugin determines which HTTP methods are allowed on various CGI directories.

			Description : By calling the OPTIONS method, it is possible to determine which HTTP methods are allowed on each directory. As this list may be incomplete, the plugin also tests - if 'Thorough tests' are enabled or 'Enable web applications tests' is set to 'yes' in the scan policy - various known HTTP methods on each directory and considers them as unsupported if it receives a response code of 400, 403, 405, or 501. Note that the plugin output is only informational and does not necessarily indicate the presence of any security vulnerabilities. Solution : n/a Plugin output : Based on the response to an OPTIONS request : - HTTP methods GET HEAD OPTIONS POST are allowed on : / /bugzilla/docs /bugzilla/docs/en /bugzilla/docs/en/html /bugzilla/images /bugzilla/skins /bugzilla/skins/contrib /bugzilla/skins/contrib/Dusk /bugzilla/skins/standard Based on tests of each method : - HTTP methods GET HEAD OPTIONS POST are allowed on : / /bugzilla /bugzilla/docs /bugzilla/docs/en /bugzilla/docs/en/html /bugzilla/images /bugzilla/skins /bugzilla/skins/contrib /bugzilla/skins/contrib/Dusk /bugzilla/skins/standard
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 24260

			Synopsis : Some information about the remote HTTP configuration can be extracted. Description : This test gives some information about the remote HTTP protocol - the version used, whether HTTP Keep-Alive and HTTP pipelining are enabled, etc... This test is informational only and does not denote any security problem. Solution : n/a Plugin output : Protocol version : HTTP/1.1 SSL : no Keep-Alive : yes Options allowed : (Not implemented) Headers : Date: Mon, 30 Jun 2014 07:51:42 GMT Server: Apache Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT ETag: "5d62b3-b1-4bd3ad8545180" Accept-Ranges: bytes Content-Length: 177 Keep-Alive: timeout=15, max=100 Connection: Keep-Alive Content-Type: text/html
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 11462 Synopsis : A bug tracker is running on the remote host. Description : The remote web server is hosting Bugzilla, a web application for bug tracking and managing software development. See also : http://www.bugzilla.org/ Solution :

			n/a Plugin output : The following instance of Bugzilla was detected on the remote host : Version : 4.4.2 URL : http://75.126.159.3-static.reverse.softlayer.com/bugzilla/query.cgi
75.126.159.3	Low	Pass	Application: unknown Port: 33494 Protocol: tcp VATID: 11111 Synopsis : An ONC RPC service is running on the remote host. Description : By sending a DUMP request to the portmapper, it was possible to enumerate the ONC RPC services running on the remote port. Using this information, it is possible to connect and bind to each service by sending an RPC request to the remote port. Solution : n/a Plugin output : The following RPC services are available on TCP port 33494 : - program: 100024 (status), version: 1
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 47830 Synopsis : Some CGIs are candidate for extended injection tests. Description : Nessus was able to inject innocuous strings into CGI parameters and read them back in the HTTP response. The affected parameters are candidates for extended injection tests like cross-site scripting attacks. This is not a weakness per se, the main purpose of this test is to speed up other scripts. The results may be useful for a human pen-tester. Solution :

n/a

Plugin output :

Using the GET HTTP method, Nessus found that :

+ The following resources may be vulnerable to injectable parameter :

+ The 'a' parameter of the /bugzilla/token.cgi CGI :

/bugzilla/token.cgi?a=reqpw&a=%00mrlizb

----- output -----

value="reqpw">

<input type="hidden" name="a"

value=".mrlizb">

<input type="hidden" name="token" value="1404114743-qaehxVqvFIRGFd [...]

<input type="submit" id="confirm" value="Yes, Confirm Changes">

+ The 'GoAheadAndLogIn' parameter of the /bugzilla/index.cgi CGI :

/bugzilla/index.cgi?GoAheadAndLogIn=%00mrlizb

----- output -----

</table>

<input type="hidden" name="GoAheadAndLogIn"

value=".mrlizb">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">

+ The 'GoAheadAndLogIn' parameter of the /bugzilla/search_plugin.cgi CGI :

/bugzilla/search_plugin.cgi?GoAheadAndLogIn=%00mrlizb

----- output -----

</table>

<input type="hidden" name="GoAheadAndLogIn"

value=".mrlizb">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">

+ The 'GoAheadAndLogIn' parameter of the /bugzilla/describecomponents.cgi CGI :

/bugzilla/describecomponents.cgi?GoAheadAndLogIn=%00mrlizb

----- output -----

</table>

<input type="hidden" name="GoAheadAndLogIn"

value=".mrlizb">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">

+ The 'GoAheadAndLogIn' parameter of the /bugzilla/enter_bug.cgi CGI :

/bugzilla/enter_bug.cgi?GoAheadAndLogIn=%00mrlizb

----- output -----

</table>

<input type="hidden" name="GoAheadAndLogIn"
value=".mrlizb">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">

+ The 'GoAheadAndLogIn' parameter of the /bugzilla/query.cgi CGI :

/bugzilla/query.cgi?GoAheadAndLogIn=%00mrlizb

----- output -----

</table>

<input type="hidden" name="GoAheadAndLogIn"
value=".mrlizb">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">

+ The 'GoAheadAndLogIn' parameter of the /bugzilla/report.cgi CGI :

/bugzilla/report.cgi?GoAheadAndLogIn=%00mrlizb

----- output -----

</table>

<input type="hidden" name="GoAheadAndLogIn"
value=".mrlizb">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">

+ The 'id' parameter of the /bugzilla/page.cgi CGI :

/bugzilla/page.cgi?id=%00mrlizb

----- output -----

</table>

<input type="hidden" name="id"
value=".mrlizb">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">

+ The 'quicksearch' parameter of the /bugzilla/buglist.cgi CGI :

			<pre> /bugzilla/buglist.cgi?quicksearch=%00mrlizb ----- output ----- </table> <input type="hidden" name="quicksearch" value=".mrlizb"> <input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in"> ----- + The 'token' parameter of the /bugzilla/createaccount.cgi CGI : /bugzilla/createaccount.cgi?token=%00mrlizb ----- output ----- <li id="mini_login_container_top"> </pre>
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 40773 Synopsis : An application was found that may use CGI parameters to control sensitive information. Description : According to their names, some CGI parameters may control sensitive data (e.g., ID, privileges, commands, prices, credit card data, etc.). In the course of using an application, these variables may disclose sensitive data or be prone to tampering that could result in privilege escalation. These parameters should be examined to determine what type of data is controlled and if it poses a security risk. ** This plugin only reports information that may be useful for auditors ** or pen-testers, not a real flaw. Solution : Ensure sensitive data is not disclosed by CGI parameters. In addition, do not use CGI parameters to control access to resources or privileges. Plugin output : Potentially sensitive parameters for CGI /bugzilla/docs/page.cgi : id : Potential horizontal or vertical privilege escalation Potentially sensitive parameters for CGI /bugzilla/page.cgi : id : Potential horizontal or vertical privilege escalation

75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 33817 Synopsis : Load estimation for web application tests. Description : This script computes the maximum number of requests that would be done by the generic web tests, depending on miscellaneous options. It does not perform any test by itself. The results can be used to estimate the duration of these tests, or the complexity of additional manual tests. Note that the script does not try to compute this duration based on external factors such as the network and web servers loads. Solution : n/a Plugin output : Here are the estimated number of requests in miscellaneous modes for one method only (GET or POST) : [Single / Some Pairs / All Pairs / Some Combinations / All Combinations] <table><tr><td>on site request forgery</td><td>: S=10</td><td>SP=10</td><td>AP=10</td><td>SC=10</td><td>AC=10</td></tr><tr><td>SQL injection</td><td>: S=1260</td><td>SP=4284</td><td>AP=4284</td><td>SC=7896</td><td>AC=7896</td></tr><tr><td>unseen parameters</td><td>: S=1575</td><td>SP=5355</td><td>AP=5355</td><td>SC=9870</td><td>AC=9870</td></tr><tr><td>local file inclusion</td><td>: S=45</td><td>SP=153</td><td>AP=153</td><td>SC=282</td><td>AC=282</td></tr><tr><td>XML injection</td><td>: S=45</td><td>SP=153</td><td>AP=153</td><td>SC=282</td><td>AC=282</td></tr><tr><td>web code injection</td><td>: S=45</td><td>SP=153</td><td>AP=153</td><td>SC=282</td><td>AC=282</td></tr><tr><td>format string</td><td>: S=90</td><td>SP=306</td><td>AP=306</td><td>SC=564</td><td>AC=564</td></tr><tr><td>script injection</td><td>: S=10</td><td>SP=10</td><td>AP=10</td><td>SC=10</td><td>AC=10</td></tr><tr><td>injectable parameter</td><td>: S=90</td><td>SP=306</td><td>AP=306</td><td>SC=564</td><td>AC=564</td></tr><tr><td>cross-site scripting (comprehensive test)</td><td>: S=180</td><td>SP=612</td><td>AP=612</td><td>SC=1128</td><td>AC=1128</td></tr><tr><td>cross-site scripting (extended patterns)</td><td>: S=60</td><td>SP=60</td><td>AP=60</td><td>SC=60</td><td>AC=60</td></tr><tr><td>directory traversal (write access)</td><td>: S=90</td><td>SP=306</td><td>AP=306</td><td>SC=564</td><td>AC=564</td></tr><tr><td>SSI injection</td><td>: S=135</td><td>SP=459</td><td>AP=459</td><td>SC=846</td><td>AC=846</td></tr><tr><td>header injection</td><td>: S=20</td><td>SP=20</td><td>AP=20</td><td>SC=20</td><td>AC=20</td></tr><tr><td>HTML injection</td><td>: S=50</td><td>SP=50</td><td>AP=50</td><td>SC=50</td><td>AC=50</td></tr><tr><td>directory traversal</td><td>: S=1305</td><td>SP=4437</td><td>AP=4437</td><td>SC=8178</td><td>AC=8178</td></tr><tr><td>arbitrary command execution (time based)</td><td>: S=270</td><td>SP=918</td><td>AP=918</td><td>SC=1692</td><td>AC=1692</td></tr><tr><td>persistent XSS</td><td>: S=180</td><td>SP=612</td><td>AP=612</td><td>SC=1128</td><td>AC=1128</td></tr><tr><td>SQL injection (2nd order)</td><td>: S=45</td><td>SP=153</td><td>AP=153</td><td>SC=282</td><td>AC=282</td></tr><tr><td>directory traversal (extended test)</td><td>: S=2295</td><td>SP=7803</td><td>AP=7803</td><td>SC=14382</td><td>AC=14382</td></tr></table>	on site request forgery	: S=10	SP=10	AP=10	SC=10	AC=10	SQL injection	: S=1260	SP=4284	AP=4284	SC=7896	AC=7896	unseen parameters	: S=1575	SP=5355	AP=5355	SC=9870	AC=9870	local file inclusion	: S=45	SP=153	AP=153	SC=282	AC=282	XML injection	: S=45	SP=153	AP=153	SC=282	AC=282	web code injection	: S=45	SP=153	AP=153	SC=282	AC=282	format string	: S=90	SP=306	AP=306	SC=564	AC=564	script injection	: S=10	SP=10	AP=10	SC=10	AC=10	injectable parameter	: S=90	SP=306	AP=306	SC=564	AC=564	cross-site scripting (comprehensive test)	: S=180	SP=612	AP=612	SC=1128	AC=1128	cross-site scripting (extended patterns)	: S=60	SP=60	AP=60	SC=60	AC=60	directory traversal (write access)	: S=90	SP=306	AP=306	SC=564	AC=564	SSI injection	: S=135	SP=459	AP=459	SC=846	AC=846	header injection	: S=20	SP=20	AP=20	SC=20	AC=20	HTML injection	: S=50	SP=50	AP=50	SC=50	AC=50	directory traversal	: S=1305	SP=4437	AP=4437	SC=8178	AC=8178	arbitrary command execution (time based)	: S=270	SP=918	AP=918	SC=1692	AC=1692	persistent XSS	: S=180	SP=612	AP=612	SC=1128	AC=1128	SQL injection (2nd order)	: S=45	SP=153	AP=153	SC=282	AC=282	directory traversal (extended test)	: S=2295	SP=7803	AP=7803	SC=14382	AC=14382
on site request forgery	: S=10	SP=10	AP=10	SC=10	AC=10																																																																																																																						
SQL injection	: S=1260	SP=4284	AP=4284	SC=7896	AC=7896																																																																																																																						
unseen parameters	: S=1575	SP=5355	AP=5355	SC=9870	AC=9870																																																																																																																						
local file inclusion	: S=45	SP=153	AP=153	SC=282	AC=282																																																																																																																						
XML injection	: S=45	SP=153	AP=153	SC=282	AC=282																																																																																																																						
web code injection	: S=45	SP=153	AP=153	SC=282	AC=282																																																																																																																						
format string	: S=90	SP=306	AP=306	SC=564	AC=564																																																																																																																						
script injection	: S=10	SP=10	AP=10	SC=10	AC=10																																																																																																																						
injectable parameter	: S=90	SP=306	AP=306	SC=564	AC=564																																																																																																																						
cross-site scripting (comprehensive test)	: S=180	SP=612	AP=612	SC=1128	AC=1128																																																																																																																						
cross-site scripting (extended patterns)	: S=60	SP=60	AP=60	SC=60	AC=60																																																																																																																						
directory traversal (write access)	: S=90	SP=306	AP=306	SC=564	AC=564																																																																																																																						
SSI injection	: S=135	SP=459	AP=459	SC=846	AC=846																																																																																																																						
header injection	: S=20	SP=20	AP=20	SC=20	AC=20																																																																																																																						
HTML injection	: S=50	SP=50	AP=50	SC=50	AC=50																																																																																																																						
directory traversal	: S=1305	SP=4437	AP=4437	SC=8178	AC=8178																																																																																																																						
arbitrary command execution (time based)	: S=270	SP=918	AP=918	SC=1692	AC=1692																																																																																																																						
persistent XSS	: S=180	SP=612	AP=612	SC=1128	AC=1128																																																																																																																						
SQL injection (2nd order)	: S=45	SP=153	AP=153	SC=282	AC=282																																																																																																																						
directory traversal (extended test)	: S=2295	SP=7803	AP=7803	SC=14382	AC=14382																																																																																																																						

			arbitrary command execution : S=990 SP=3366 AP=3366 SC=6204 AC=6204 blind SQL injection (4 requests) : S=180 SP=612 AP=612 SC=1128 AC=1128 HTTP response splitting : S=90 SP=90 AP=90 SC=90 AC=90 blind SQL injection : S=1350 SP=4590 AP=4590 SC=8460 AC=8460 All tests : S=10410 SP=34818 AP=34818 SC=63972 AC=63972 Here are the estimated number of requests in miscellaneous modes for both methods (GET and POST) : [Single / Some Pairs / All Pairs / Some Combinations / All Combinations] on site request forgery : S=20 SP=20 AP=20 SC=20 AC=20 SQL injection : S=2520 SP=8568 AP=8568 SC=15792 AC=15792 unseen parameters : S=3150 SP=10710 AP=10710 SC=19740 AC=19740 local file inclusion : S=90 SP=306 AP=306 SC=564 AC=564 XML injection : S=90 SP=306 AP=306 SC=564 AC=564 web code injection : S=90 SP=306 AP=306 SC=564 AC=564 format string : S=180 SP=612 AP=612 SC=1128 AC=1128 script injection : S=20 SP=20 AP=20 SC=20 AC=20 injectable parameter : S=180 SP=612 AP=612 SC=1128 AC=1128 cross-site scripting (comprehensive test): S=360 SP=1224 AP=1224 SC=2256 AC=2256 cross-site scripting (extended patterns) : S=120 SP=120 AP=120 SC=120 AC=120 directory traversal (write access) : S=180 SP=612 AP=612 SC=1128 AC=1128 SSI injection : S=270 SP=918 AP=918 SC=1692 AC=1692 header injection : S=40 SP=40 AP=40 SC=40 AC=40 HTML injection : S=100 SP=100 AP=100 SC=100 AC=100 directory traversal : S=2610 SP=8874 AP=8874 SC=16356 AC=16356 arbitrary command execution (time based) : S=540 SP=1836 AP=1836 SC=3384 AC=3384 persistent XSS : S=360 SP=1224 AP=1224 SC=2256 AC=2256 SQL injection (2nd order) : S=90 SP=306 AP=306 SC=564 AC=564 directory traversal (extended test) : S=4590 SP=15606 AP=15606 SC=28764 AC=28764 arbitrary command execution : S=1980 SP=6732 AP=6732 SC=12408 AC=12408 blind SQL injection (4 requests) : S=360 SP=1224 AP=1224 SC=2256 AC=2256 HTTP response splitting : S=180 SP=180 AP=180 SC=180 AC=180 blind SQL injection : S=2700 SP=9180 AP=9180 SC=16920 AC=16920 All tests : S=20820 SP=69636 AP=69636 SC=127944 AC=127944 Your mode : single, GET and POST, experimental tests. Maximum number of requests : 20820
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 39470 Synopsis : Some generic CGI attacks ran out of time.

			Description : Some generic CGI tests ran out of time during the scan. The results may be incomplete. Solution : Consider increasing the 'maximum run time (min)' preference for the 'Web Application Tests Settings' in order to prevent the CGI scanning from timing out. Less ambitious options could also be used, such as : - Combinations of arguments values = 'all combinations' is much slower than 'two pairs' or 'single'. - Stop at first flaw = 'per port' is quicker. - In 'some pairs' or 'some combinations' mode, try reducing web_app_tests.tested_values_for_each_parameter in nessusd.conf Plugin output : The following tests timed out without finding any flaw : - SQL injection (on HTTP headers) - SQL injection - directory traversal - arbitrary command execution
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: udp VATID: 10287 Synopsis : It was possible to obtain traceroute information. Description : Makes a traceroute to the remote host. Solution : n/a Plugin output : For your information, here is the traceroute from 38.123.140.114 to 75.126.159.3 : <pre> 38.123.140.114 38.123.140.1 38.122.22.61 154.24.24.1 154.54.85.149 154.54.42.89 154.54.41.53 </pre>

			4.68.63.173 4.53.116.66 173.192.18.153 173.192.18.134 173.192.18.213 66.228.118.182 75.126.159.3
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 10180 Synopsis : It was possible to identify the status of the remote host (alive or dead) Description : This plugin attempts to determine if the remote host is alive using one or more ping types : - An ARP ping, provided the host is on the local subnet and Nessus is running over ethernet. - An ICMP ping. - A TCP ping, in which the plugin sends to the remote host a packet with the flag SYN, and the host will reply with a RST or a SYN/ACK. - A UDP ping (DNS, RPC, NTP, etc). Solution : n/a Plugin output : The remote host is up The remote host replied to an ICMP echo packet
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 12053 Synopsis : It was possible to resolve the name of the remote host. Description : Nessus was able to resolve the FQDN of the remote host. Solution :

			n/a Plugin output : 75.126.159.3 resolves as 75.126.159.3-static.reverse.softlayer.com.
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 50350 Synopsis : It was not possible to determine the remote operating system. Description : Using a combination of remote probes (TCP/IP, SMB, HTTP, NTP, SNMP, etc), it was possible to gather one or more fingerprints from the remote system. Unfortunately, though, Nessus does not currently know how to use them to identify the overall system. Solution : n/a Plugin output : If you think these signatures would help us improve OS fingerprinting, please send them to : os-signatures@nessus.org Be sure to include a brief description of the device itself, such as the actual operating system or product / model names. HTTP!!Server: Apache SMTP!!554 trainpetdoga.com.com ESMTP not accepting messages 550 5.0.0 Command rejected 500 5.5.1 Command unrecognized: ""
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 45590 Synopsis : It is possible to enumerate CPE names that matched on the remote system. Description : By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

			Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan. See also : http://cpe.mitre.org/ Solution : n/a Plugin output : Following application CPE's matched on the remote system : cpe:/a:mozilla:bugzilla:4.4.2 -> Mozilla Bugzilla 4.4.2 cpe:/a:isc:bind:9
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: icmp VATID: 10114 Synopsis : It is possible to determine the exact time set on the remote host. Description : The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols. Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time. Solution : Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14). Plugin output : The difference between the local and remote clocks is 2 seconds. CVE : CVE-1999-0524 Other references : OSVDB:94, CWE:200
75.126.159.3	Low	Pass	Application: sunrpc Port: 111 Protocol: udp VATID: 10223 Synopsis :

			An ONC RPC portmapper is running on the remote host. Description : The RPC portmapper is running on this port. The portmapper allows someone to get the port number of each RPC service running on the remote host by sending either multiple lookup requests or a DUMP request. Solution : n/a CVE : CVE-1999-0632
75.126.159.3	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 14772 Synopsis : This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to identify common services which might have been missed because of a network problem. Solution : See below Plugin output : An FTP server is running on this port
75.126.159.3	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 10092 Synopsis : An FTP server is listening on this port. Description : It is possible to obtain the banner of the remote FTP server by connecting to the remote port. Solution : n/a

			Plugin output : The remote FTP banner is : 220 (vsFTPD 2.3.2)
75.126.159.3	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 52703 Synopsis : An FTP server is listening on the remote port. Description : The remote host is running vsftpd, an FTP server for UNIX-like systems written in C. See also : http://vsftpd.beasts.org/ Solution : n/a Plugin output : Source : 220 (vsFTPD 2.3.2) Version : 2.3.2
75.126.159.3	Low	Pass	Application: domain Port: 53 Protocol: udp VATID: 11002 Synopsis : A DNS server is listening on the remote host. Description : The remote service is a Domain Name System (DNS) server, which provides a mapping between hostnames and IP addresses. See also : http://en.wikipedia.org/wiki/Domain_Name_System Solution : Disable this service if it is not needed or restrict access to internal hosts only if the service is available externally.
75.126.159.3	Low	Pass	Application: domain

			Port: 53 Protocol: udp VATID: 11951 Synopsis : It may be possible to fingerprint the remote DNS server. Description : This script attempts to identify the remote DNS server type and version by sending various invalid requests to the remote DNS server and analyzing the error codes returned. See also : http://cr.yip.to/surveys/dns1.html Solution : n/a Plugin output : The remote name server could be fingerprinted as being : ISC BIND 9.8.2
75.126.159.3	Low	Pass	Application: domain Port: 53 Protocol: udp VATID: 35371 Synopsis : The DNS server discloses the remote host name. Description : It is possible to learn the remote host name by querying the remote DNS server for 'hostname.bind' in the CHAOS domain. Solution : It may be possible to disable this feature. Consult the vendor's documentation for more information. Plugin output : The remote host name is : trainpetdoga.com
75.126.159.3	Low	Pass	Application: domain Port: 53 Protocol: tcp VATID: 11002

			Synopsis : A DNS server is listening on the remote host. Description : The remote service is a Domain Name System (DNS) server, which provides a mapping between hostnames and IP addresses. See also : http://en.wikipedia.org/wiki/Domain_Name_System Solution : Disable this service if it is not needed or restrict access to internal hosts only if the service is available externally.
75.126.159.3	Low	Pass	Application: domain Port: 53 Protocol: tcp VATID: 10728 Synopsis : The remote name server can be fingerprinted. Description : It was possible to determine that the remote name server is running BIND 9.x by querying it for the AUTHORS map. Solution : Change the source code to prevent fingerprinting the server.
75.126.159.3	Low	Pass	Application: sunrpc Port: 111 Protocol: udp VATID: 11111 Synopsis : An ONC RPC service is running on the remote host. Description : By sending a DUMP request to the portmapper, it was possible to enumerate the ONC RPC services running on the remote port. Using this information, it is possible to connect and bind to each service by sending an RPC request to the remote port. Solution : n/a Plugin output :

			The following RPC services are available on UDP port 111 : - program: 100000 (portmapper), version: 4 - program: 100000 (portmapper), version: 3 - program: 100000 (portmapper), version: 2
75.126.159.3	Low	Pass	Application: sunrpc Port: 111 Protocol: tcp VATID: 53335 Synopsis : An ONC RPC portmapper is running on the remote host. Description : The RPC portmapper is running on this port. The portmapper allows someone to get the port number of each RPC service running on the remote host by sending either multiple lookup requests or a DUMP request. Solution : n/a
75.126.159.3	Low	Pass	Application: sunrpc Port: 111 Protocol: tcp VATID: 11111 Synopsis : An ONC RPC service is running on the remote host. Description : By sending a DUMP request to the portmapper, it was possible to enumerate the ONC RPC services running on the remote port. Using this information, it is possible to connect and bind to each service by sending an RPC request to the remote port. Solution : n/a Plugin output : The following RPC services are available on TCP port 111 : - program: 100000 (portmapper), version: 4 - program: 100000 (portmapper), version: 3 - program: 100000 (portmapper), version: 2
75.126.159.3	Low	Pass	Application: smtp Port: 25

			Protocol: tcp VATID: 14772 Synopsis : This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to identify common services which might have been missed because of a network problem. Solution : See below Plugin output : A SMTP server is running on this port
75.126.159.3	Low	Pass	Application: ntp Port: 123 Protocol: udp VATID: 10884 Synopsis : An NTP server is listening on the remote host. Description : An NTP (Network Time Protocol) server is listening on this port. It provides information about the current date and time of the remote system and may provide system information. Solution : n/a
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 14772 Synopsis : This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to identify common services which might have been missed because of a network problem. Solution : See below

			Plugin output : A web server is running on this port
--	--	--	---

CONFIDENTIALITY: This email (including any attachments) may contain confidential, proprietary and privileged information. Unauthorized disclosure or use is prohibited. If you received this email in error, please notify the sender and delete this email from your system.